情報処理安全確保支援士試験　科目A-2　中分類24 情報セキュリティマネジメント　#07

組織・機関と制度・基準

だれが何を担い、どの制度・指針に従うのか。名前と役割の取り違えを防ぐ

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、経済産業省・IPA・NIST・ISMAP 運営委員会の公表資料、RFC など）を書いた。過去問は IPA 公開の午前 II

全体像 シラバス案 中分類24 小分類3「諸規程」・小分類4「関連組織・関連制度」

1 社内の規程と体制
情報セキュリティ方針・インシデント対応規程・プライバシーポリシー、委員会・CSIRT・PSIRT・SOC、abuse@・security@

2 国内外の機関
戦略本部・NCO、JPCERT/CC・FIRST・ISAC・J-CSIP・NOTICE、CRYPTREC・NIST・MITRE

3 届出・評価の制度
ウイルス・不正アクセス届出、早期警戒パートナーシップ、29147/30111、SECURITY ACTION、サービス基準、ISMAP、SCS 評価制度

4 指針・フレームワーク・規格
統一基準群、経営ガイドライン、中小企業ガイドライン、CPSF、NIST CSF・SP 800、27701、42001、AI 事業者ガイドライン

過去の午前Ⅱでの出方（令和2〜7年度）

テーマ	出た回
NOTICE の説明	R2・R4春・R5秋
CRYPTREC の活動	R2・R4春
NIST CSF のコア	R5春・R7春
ISMAP・ISMAP-LIU・管理基準	R5春・R6春・R7春
経営 GL・CPSF・SECURITY ACTION	R2・R4春
MITRE・PSIRT・SIM3・J-CSIP	R3春・R6春・R7秋

> この分野は**毎回2〜3問**出る。選択肢は**ほかの機関・制度の説明**で作られる。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類24 小分類3・4／IPA 午前Ⅱ 各回（このPDFの問題演習を参照）

第1章

社内の規程と体制

方針は経営が決め、見張りと対応はチームで分ける。

規程の3階層と、社内の体制

基本方針
なぜ・何を守るか（トップが表明）

↓

対策基準
何をするか（規程・ルール）

↓

実施手順
どうやるか（手順書・マニュアル）

ほかに**インシデント対応規程**（報告先・判断基準・役割・外部連絡）、**プライバシーポリシー**（外部向けの個人情報保護方針）。

体制	扱うもの
情報セキュリティ委員会	方針の決定・リスク対応の承認・全社の調整（CISO が率いる）
CSIRT	**自組織**で起きたインシデントの受付・対応・調整
PSIRT	**自社製品**の脆弱性の受付・調査・修正・公表
SOC	ログ・通信を24時間**監視**して検知・通知
WHOIS の技術連絡担当	ドメイン名・IP の登録情報の連絡先

出典：IPA「支援士試験 シラバス（案）」中分類24 小分類3・4 用語例／IPA 午前 II 令和7年度秋期 問13（PSIRT が正解）

外から連絡してもらうための窓口と、成熟度の評価

役割ごとのメールアドレス（RFC 2142）

abuse@	自組織からの迷惑メール・攻撃の苦情
noc@	ネットワークの運用
security@	セキュリティの問題・脆弱性の報告

security.txt（RFC 9116）

```
https://example.jp/.well-known/security.txt
Contact: mailto:security@example.jp
Expires: 2027-03-31T00:00:00.000Z
Policy: https://example.jp/vuln-policy
```

R6春 問8：CSIRT の成熟度モデルは

名前	何の成熟度
CMMC	米国防総省の取引先のサイバーセキュリティ
CMMI	開発などのプロセスの能力
SAMM	OWASP のソフトウェア保証
SIM3	インシデント管理（Open CSIRT Foundation）

> SIM3 は組織・人・ツール・プロセスの4分野で評価する。

出典：RFC 2142 Mailbox Names for Common Services／RFC 9116 security.txt／IPA 午前 II 令和6年度春期 問8

第2章

国内外の機関

「その仕事はどこがするか」を言い当てる。

国内の機関の地図

サイバーセキュリティ戦略本部（内閣）
戦略の案・統一基準群の決定。本部長は内閣官房長官

↓ 事務・総合調整

国家サイバー統括室 NCO（内閣官房）
2025年に NISC を改組。政府全体の司令塔

IPA（経産省）
届出受付・ガイドライン・J-CSIP・試験

NICT（総務省）
NICTER 観測・NOTICE

JPCERT/CC
インシデント・脆弱性の調整

取組	中身
J-CSIP	IPA が中継し、参加組織で**標的型攻撃の情報を共有**（R3春）
NOTICE	総務省・NICT。推測されやすい**パスワードでログインを試し**、危険な IoT 機器を ISP 経由で注意喚起（R2・R4春・R5秋）
NICTER	NICT。ダークネット観測で感染した機器や攻撃の傾向を分析
ISAC	同じ業界での情報共有（金融 ISAC・ICT-ISAC など）

出典：IPA「支援士試験 シラバス（案）」用語例／サイバーセキュリティ基本法／IPA 午前 II 令和3年度春期 問9・令和5年度秋期 問10

標準化・技術評価の機関：CRYPTREC・NIST・MITRE・FIRST

機関	役割	関係するもの
CRYPTREC	暗号技術の安全性の評価・監視、実装法・運用法の検討（日本）	CRYPTREC 暗号リスト（#15）
NIST	米国の標準・ガイドラインの発行（商務省）	CSF・SP 800・FIPS・AES・NVD
MITRE	米国の非営利組織。CVE の運営、攻撃のナレッジベースの公開	CVE・CWE・ATT&CK
FIRST	世界の CSIRT の国際フォーラム	CVSS・TLP・PSIRT Services Framework
ENISA	EU 加盟国のサイバーセキュリティを支援	—

R4春 問10 CRYPTREC の誤り：基本戦略の立案（NISC）、ISMS の認証（認証機関）、暗号モジュールの試験（JCMVP の試験機関）。

R7秋 問12 MITRE の誤り：CSF・ガイドラインの発行（NIST）、EU の支援（ENISA）、国内インシデントの受付（JPCERT/CC）。

出典：IPA 午前 II 令和4年度春期 問10・令和7年度秋期 問12／IPA「支援士試験 シラバス（案）」用語例

第3章

届出・評価の制度

だれが届け出て、だれが評価し、どこに載るのか。

届出と脆弱性の公表の流れ

IPA への届出（経済産業省の告示にもとづく）

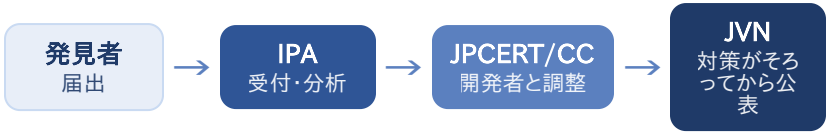
ウイルス届出	ウイルスの発見・感染
不正アクセス届出	不正アクセスの被害

義務ではない。被害の拡大防止のための情報収集。警察への被害届とは別。

脆弱性の国際規格

ISO/IEC 29147	開示（受付と公表、**外**とのやりとり）
ISO/IEC 30111	取扱い（調査と修正、**中**の処理）

早期警戒パートナーシップ（ソフトウェア製品）



Web サイトの脆弱性は IPA が運営者に直接連絡し、JVN では公表しない。

被害情報の共有・公表ガイダンス（2023）：被害組織の名前を伏せた**攻撃の技術情報**は早く共有するほど他組織を守れる。公表とは分けて考える。

出典：IPA「情報セキュリティ早期警戒パートナーシップガイドライン」／内閣官房ほか「サイバー攻撃被害に係る情報の共有・公表ガイダンス」（2023）／ISO/IEC 29147・30111

評価・登録の制度：自己宣言か、第三者か

制度	対象	だれが評価	取り違えやすいもの
SECURITY ACTION	中小企業の取組（★一つ星・★★二つ星）	自己宣言	ISMS 適合性評価
ISMS 適合性評価	組織の ISMS（JIS Q 27001）	認証機関	—
JISEC	IT 製品のセキュリティ機能（ISO/IEC 15408）	評価機関・認証機関	ISMS
情報セキュリティサービス基準	監査・診断・フォレンジック・監視のサービス	IPA が審査しリスト掲載	—
ISMAP	政府が使うクラウドサービス	監査機関の評価→登録	ISMS クラウド認証
ISMAP-LIU	**リスクの小さい業務**に使う SaaS	同上（簡略）	SOC2 報告書
SCS 評価制度	取引先の対策の段階（★3〜★5）	自己評価＋専門家／第三者	—

R5春 問8：ISMAP 管理基準の基礎は**日本セキュリティ監査協会「クラウド情報セキュリティ管理基準（平成28年度版）」**。FIPS 140-3、ISO/IEC 27018、JIS Q 15001 は違う。

出典：IPA 午前 II 令和4年度春期 問7・令和5年度春期 問8・令和6年度春期 問7・令和7年度春期 問11／経済産業省「SCS 評価制度」中間取りまとめ（2025）

第4章

指針・フレームワーク・規格

読み手（政府・経営者・中小企業・あらゆる組織）で整理する。

国内の指針：だれのためのものか

指針	読み手と中身
統一基準群	政府機関・独法。ベースラインとより高い水準の対策事項（戦略本部が決定）
経営ガイドライン	経営者。**3原則と重要10項目**（Ver3.0、2023）。対策は「**投資**」
中小企業ガイドライン	中小企業。5か条・自社診断・ひな形。SECURITY ACTION の基準
CPSF	産業界。Society5.0 の**三層構造と6つの構成要素**でリスクを捉える
つながる世界の開発指針	IoT の開発者。17の指針（IPA、2016）
AI 事業者ガイドライン	AI の開発者・提供者・利用者（総務省・経産省、2024）

R4春 問9 の誤り：「投資ではなく**コスト**として捉える」（逆）、「全ての経営者が適用すべき対策を定めた」（一律ではない）、「小規模事業者の事後対応」（範囲が違う）。

R2 問7 CPSF の誤り：テレワーク（テレワークセキュリティガイドライン）、利用者向けと提供者向けの対の手引（ISO/IEC 27017）、データセンタの知見。

出典：経済産業省・IPA「サイバーセキュリティ経営ガイドライン Ver 3.0」／経済産業省「CPSF」／IPA 午前 II 令和4年度春期 問9・令和2年度 問7

NIST CSF 2.0：6つの機能

GOVERN 統治
2.0 で追加。戦略・方針・役割・監督

＋

IDENTIFY 識別
資産・リスク

PROTECT 防御
アクセス制御・教育

DETECT 検知
監視

RESPOND 対応
分析・封じ込め

RECOVER 復旧
計画・改善

R5春 問9 の選択肢	正体
観察・状況判断・意思決定・行動	OODA ループ
識別・防御・検知・対応・復旧	CSF 1.1 のコア（正解）
準備・検知と分析・封じ込め/根絶/復旧・事件後の対応	SP 800-61 Rev.2
責任・戦略・取得・パフォーマンス・適合・人間行動	JIS Q 38500 の6原則

R7春 問12：6つ目は **GOVERN**。CONTROL・DIRECT・MANAGE はない。

コア（機能・カテゴリ・サブカテゴリ）、プロファイル（現状と目標）、ティア（4段階の取組の度合い）。

出典：NIST「The NIST Cybersecurity Framework (CSF) 2.0」（2024）／IPA 午前 II 令和5年度春期 問9・令和7年度春期 問12

NIST SP 800 シリーズと分野別の規格

シラバス案に名前が出る SP 800

SP 800-53	セキュリティとプライバシーの管理策の一覧
SP 800-61	インシデント対応の手引き（Rev.3 は CSF 2.0 に合わせた）
SP 800-171	政府以外の組織にある CUI（重要な非機密情報）の保護
SP 800-207	ゼロトラストアーキテクチャ（#18）

分野別の規格

JIS Q 27701	プライバシー情報マネジメント（PIMS）。ISMS を拡張
ISO/IEC 42001	AI マネジメントシステム（2023）
ISO/IEC 27017	クラウドサービスの管理策（利用者・提供者の対）
ISO/IEC 27018	パブリッククラウドでの PII 保護
JIS Q 15001	個人情報保護（プライバシーマークの基準）

出典：IPA「支援士試験 シラバス（案）」用語例「NIST SP 800 シリーズ」「JIS Q 27701」「ISO/IEC 42001」／NIST SP 800-61 Rev.3（2025）

まとめ：選択肢の作られ方

機関の問題：正解以外は「ほかの機関の役割」。CRYPTREC・NIST・MITRE・JPCERT/CC・NISC(NCO)・ENISA の役割を一言で言えるように。

制度の問題：自己宣言（SECURITY ACTION）か、第三者（ISMS・JISEC・ISMAP）か。対象は組織・製品・サービス・クラウドのどれか。

フレームワークの問題：CSF のコアの機能の名前、OODA・SP 800-61・JIS Q 38500 の並びと区別。

新シラバスの新顔：NCO、SCS 評価制度、被害情報の共有・公表ガイダンス、29147/30111、ISO/IEC 42001、AI 事業者ガイドライン、SP 800-171・207。

出典：IPA 午前 II 令和2〜7年度（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」